

[doc. web n. 10126141]
Provision of February 27, 2025
Register of Provisions
No. 116 of February 27, 2025

THE GUARANTOR FOR THE PROTECTION OF PERSONAL DATA

IN THE meeting held today, attended by
Prof. Pasquale Stanzione, President, Prof.
Ginevra Cerrina Feroni, Vice President, Dr.
Agostino Ghiglia and Attorney Guido Scorza, members, and
Secretary General Fabio Mattei;

HAVING REGARD to Regulation (EU) 2016/679 of the European Parliament and of the Council, of April 27, 2016 (hereinafter "Regulation");

HAVING REGARD to Legislative Decree of June 30, 2003, No. 196 (Code regarding the protection of personal data, hereinafter "Code") as amended by Legislative Decree of August 10, 2018, No. 101 containing "Provisions for the adaptation of national legislation to the provisions of Regulation (EU) 2016/679";

HAVING REGARD to Regulation No. 1/2019 concerning internal procedures with external relevance, aimed at carrying out the tasks and exercising the powers entrusted to the Guarantor for the protection of personal data, approved by resolution No. 98 of 04/04/2019, published in G.U. No. 106 of 08/05/2019 and on www.gpdp.it, doc. web No. 9107633 (hereinafter "Regulation No. 1/2019");

HAVING EXAMINED the documentation on file;

HAVING REGARD to the observations made by the Secretary General pursuant to Article 15 of the Guarantor's Regulation No. 1/2000;

REPORTING Prof. Pasquale Stanzione;

PREMISE

1. Introduction.

With a complaint submitted pursuant to Article 77 of the Regulation, Mr. XX complained of a violation of the rules regarding the protection of personal data by the Ministry of the Interior - Department for Internal and Territorial Affairs, in relation to the processing of personal data carried out through the service called "CIE-Online Agenda," available on the Ministry's official website (<https://www.prenotazionicie.interno.gov.it/>) for the purpose of booking an appointment at a Municipality to submit the request for the electronic identity card.

In particular, on XX, the complainant, using the aforementioned service, scheduled an appointment for the renewal of the expiring identity card, confirming the appointment via SPID. At the end of the process, he received a summary message on screen from which he noted that his data would be sent to an email address not attributable to him. This anomaly occurred "despite the information on the SPID portal being correct." Specifically, according to what was complained of in the complaint, "the system had created the profile by entering an incorrect email," XX (hereinafter name.surname@xy.com) and "the result of this system error caused Mr. XX" [hereinafter "Name Surname"], whose email address was incorrectly reported in the personal profile sheet of the applicant present on the platform, "to receive an email containing the [...] personal data [of the complainant] summarized in a pdf," relating to the appointment of XX, for the issuance of the electronic identity card.

2. The Investigation.

2.1. The investigative activity

In response to the Authority's request for information, pursuant to Article 157 of the Code, the Ministry of the Interior, Department for Internal and Territorial Affairs (hereinafter "Ministry"), with note of XX, stated that:

- "From the technical checks carried out by the State Polygraphic Institute, on the 'CIE-Online Agenda'

system, it emerged that, on XX, a user account was created on the aforementioned system in the name of [the complainant], with email address [name.surname@xy.com], and on the same day an appointment was scheduled in the name of the interested party [...] for the day XX; [...]

- it was also found that there exists a SCO (smart card provided to municipalities necessary for the issuance of Electronic Identity Cards) of the Municipality of XX, assigned to [Name Surname], who should therefore be a municipal operator. The latter could have plausibly registered the appointment on the Agenda, in the name and on behalf of the [complainant], indicating his own address as the contact email [...];

- "on XX, it appears that the [complainant] accessed the Agenda system, authenticating himself with his SPID credentials (the system allows access with CIE, SPID or proprietary credentials) and proceeded to book a new appointment at the [Municipality], using the data registered in the previously created account, on XX. At the end of the booking, the system informed the user [...] that the PDF receipt of the appointment had been sent, via email, to the address entered on XX, [name.surname@xy.com]";

- "the interested party – reading an email address different from his own (i.e., the one entered during the creation of the account on XX) – contacted CIE assistance on XX, requesting verification regarding the incident";

- "CIE assistance contacted the interested party, informing him of the data that was registered in the Agenda system and the methods for modifying the data entered during registration [...]. The PDF receipt of the appointment was generated again by the system and sent to the address XX, after the modification of the same following contact with CIE assistance";

- "Unless the user implements the account deletion procedure [...] the data of citizens are retained within the limits of

****Prescription of Actionable Rights****

In response to the further request for elements from XX, the aforementioned Ministry, with a note dated XX, received on XX, declared that:

- "Regarding the methods of associating the data entered, through a counter operator, to the user profile subsequently linked to a SPID account, it is specified that, in this case, the account was created, presumably by the municipal operator [...] using the procedure reserved for citizens. In the case of subsequent access to the AgendaOnline system using SPID credentials, the user profile is associated via the tax code to the account previously created."

- "There is a specific functionality dedicated to the counter operator that allows them to schedule an appointment on behalf of the user [...]; the procedure through which counter operators can make appointments for citizens requires the entry of an email address freely chosen by the citizen; it is therefore not possible to foresee a control of the email address belonging to a specific domain. The only system to modify the email address stored in the citizen's profile is for the citizen to access the portal with their own credentials; operators, in fact, do not have a procedure that allows them to create or modify the user profile of citizens."

- "In relation to the risk of sending communications to a previously entered address [...] no longer deemed suitable by the interested party, the Poligrafico has been asked to verify a possible implementation [...] of a notification to the user that allows them to view the email address to which the appointment confirmation is about to be sent and to proceed with any corrections, despite - it is emphasized - the user already having the possibility, [...] to modify the previously entered email address through the user profile management functionality."

****2.2. Notification of Violations and Defensive Memoranda****

In relation to the above, with a note dated XX, the Office, based on the elements acquired and the facts emerged following the investigative activity, notified the Ministry of the Interior, pursuant to Article 166, paragraph 5, of the Code, of the initiation of proceedings for the adoption of measures referred to in Article 58, paragraph 2, of the Regulation, as the personal data of users, acquired during bookings, were stored in the "CIE-Agenda Online" system for a period longer than necessary to achieve the purposes for which they were collected (booking an appointment to submit a request for a CIE at the chosen municipal office). In fact, the data related to users' bookings, including those canceled or

expired, remained recorded in the system even after the date of the booked appointment, even after the issuance of the CIE, in the absence of a legal basis and in violation of Articles 5, paragraph 1, letters a), b), e), and f), and 6 of the Regulation.

In relation to these allegations, the Ministry was invited to produce defensive writings or documents, requesting, if necessary, to be heard by the Authority (Article 166, paragraphs 6 and 7, of the Code; as well as Article 18, paragraph 1, of Law No. 689 of November 24, 1981).

With a note dated XX, the Ministry transmitted its defensive memoranda regarding the contested violations, stating, in particular, that:

- From the analysis of the data recorded in the CIE system, it also emerged that [Name Surname] was the holder of an operator smart card (SCO) assigned to the Municipality [...], [where] they served [...] as a registry official until XX [...]. The aforementioned employee, connected by a friendship with the claimant's uncle, would have provided support for booking the first appointment recorded in the CIE system in the name of [the claimant], providing their email account.

- [...] the Decree of December 23, 2015, Annex B, point 4.4.5. (Acquisition of contact addresses of the applicant) states that "At the time of the request for the issuance of the CIE at the Municipality or the Consulate, the citizen may provide contact addresses, such as phone number, email address [...] in order to receive communications from CIEonLine regarding the status of the CIE issuance process."

This provision therefore legitimizes the collection by the CIE system of the email address communicated by the applicant and its retention to enable communications regarding the document issuance process until it is concluded. For this reason, the CIE system retained the personal data entered on XX for the appointment on XX and proposed it [to the claimant] on XX for the new appointment scheduled for the following February 8, since the process of issuing the CIE in favor of the applicant was still ongoing.

- [...] based on the information made available at the time of registration for the CIE service, the duration of the processing of the collected personal data is permitted for a period not exceeding two years from the date of such registration or [...] from the last appointment, after which the data is deleted. Verifying the dates of the complaint in question [...] since two years had not passed either between the two accesses to the Agenda CIE system or between the two dates of the appointments set for the issuance of the document, also in relation to compliance with retention times, the processing of personal data [of the claimant], for purposes related to the issuance of the CIE, appears consistent with the provisions.

***"suindicate".**

- "Following the modification of the address made by the interested party assisted by the CIE support service, the system promptly generated a new appointment receipt, sent to the new address registered by the user";

- "the aforementioned incident involved the data of only one citizen and [...] to date, no similar reports have been received by either the Ministry or the Poligrafico, via help desk."

Regarding what was noted by the Authority, more generally, concerning the "CIE-Online Agenda" system, the Ministry stated that, "utilizing the technical support of the Poligrafico, with a view to privacy by design and by default, it has planned to implement the following corrective measures to the CIE system:

- publish a specific notice on the CIE Agenda Portal that draws the citizen's attention to the fact that the creation of the account is necessary for managing the appointment and that it will be automatically deleted in the absence of active appointments, also ensuring that the information is updated by December 15 of this year;

- delete accounts and data related to scheduled appointments following the issuance of the CIE, if there are no further ongoing appointments;

- delete from the system the history of all appointments made by the interested parties (appointment number, date, time, office) and all accounts by December 15 of this year."

The Ministry finally declared itself "available to undertake any other initiative deemed necessary to ensure the protection of the personal data in question."

****2.3. Further Investigations.****

Taking into account the elements acquired during the investigation and the measures that the Ministry of the Interior has declared it will adopt in order to overcome the issues contested by the Guarantor, the Office has ascertained that, following the intervention of the aforementioned Ministry, the "CIE Online Agenda" system allows access to the appointment booking service, not only with CIE and SPID but also based on a simple registration procedure, which requires the entry of the tax code and a password. In this regard, the information provided to users specifies that "In the event that SPID credentials are not available, CIE Agenda allows registration for the service. Registration requires that the same data provided by SPID to the service be supplied" (cf.

<https://www.prenotazionicie.interno.gov.it/informativa/privacy>). The Office has also ascertained that, as stated in the aforementioned information, "The cancellation of appointments occurs 30 days after the date of the same, regardless of the issuance of the CIE. Accounts are deleted when there is no appointment associated with them. It follows that if an account is associated with only one appointment, upon cancellation of this (30 days after expiration), the account will also be deleted, but if the account is associated with an appointment that is not expired or expired less than 30 days prior, the account will not be deleted" and that it is, in any case, possible to proceed with the cancellation "directly on the web portal by accessing the 'Account Deletion' functionality."

****3. Outcome of the Investigative Activity.****

Preliminarily, it is represented that the processing of personal data must occur in compliance with the applicable regulations regarding the protection of personal data and, in particular, the provisions of Regulation (EU) 2016/679 and the Code.

In particular, the processing of personal data carried out by public entities is lawful only if necessary "to comply with a legal obligation to which the data controller is subject" or "for the performance of a task carried out in the public interest or in the exercise of official authority vested in the data controller" (Articles 6, paragraph 1, letters c) and e), of the Regulation, 2-ter of the Code) and must occur, in any case, in compliance with the principles regarding the protection of personal data, particularly the principles of "lawfulness, fairness, and transparency" and "purpose limitation," "storage limitation," under which data are "processed lawfully, fairly, and transparently in relation to the data subject," "collected for specified, legitimate purposes and subsequently processed in a manner that is not incompatible with those purposes" and "kept in a form which permits identification of data subjects for no longer than is necessary for the purposes for which the personal data are processed" (Article 5, paragraph 1, letters a), b), and e) and the data controller must be able to demonstrate the adoption of the aforementioned measures and the compliance of the processing with the Regulation (Articles 5, paragraph 2, and 24, paragraph 1, of the Regulation). Furthermore, based on the principle of "data protection by design," as set out in Article 25, paragraph 1, of the Regulation, the data controller, taking into account the state of the art and the costs of implementation, as well as the nature, scope, context, and purposes of the processing, as well as the risks of varying likelihood and severity for the rights and freedoms of natural persons posed by the processing, both at the time of determining the means of processing and at the time of the processing itself, must implement appropriate technical and organizational measures to effectively apply the principles of data protection and to integrate the necessary safeguards into the processing to meet the requirements of the Regulation and protect the rights of data subjects.

From the ascertainment carried out based on the elements acquired and the facts that emerged following the activity...

****Investigation Report****

Following the investigation and subsequent evaluations of this Department, it has been established that the claimant on XX, used the website <https://www.prenotazionicie.interno.gov.it/> to schedule an appointment for the renewal of the expiring identity card, confirming the appointment via SPID. At the end of the process, the system displayed a summary screen indicating that the claimant's data would be sent to an unknown email address; this, despite the information on the SPID portal being correct.

The Ministry of the Interior, with notes dated XX and XX, and with defensive memoranda dated XX, has provided the following elements, summarized for relevant aspects, including technical details:

1. The booking system utilizes a database in which it stores data related to the management of appointments and the availability calendars of municipal offices;
2. Based on technical checks carried out by the State Polygraphic Institute on behalf of the Ministry regarding the "CIE-Online Agenda" system, it emerged that, on XX, a user account was created in the name of the claimant, with the email address [name.surname@xy.com], and on the same day, an appointment was scheduled for the day XX;
3. It was found that there was a SCO (smart card assigned to municipal employees necessary for issuing Electronic Identity Cards) of the Municipality assigned to Mr. [Name Surname];
4. The user account created on the "CIE-Online Agenda" system contained the email address indicated in the complaint, referring to the aforementioned municipal operator, as the latter presumably used the procedure reserved for citizens;
5. At the time of the events, the duration for the retention of personal data was set "for a period not exceeding two years from the date of the registration itself or [...] of the last appointment, after which the data is deleted";
6. Checking the timing of the events subject to the complaint "since two years had not passed either between the two accesses to the CIE Agenda system or between the two dates of the appointments scheduled for the issuance of the document," the claimant's data was still retained in the user profile;
7. On XX, at the moment when the interested party accessed the system by authenticating with their SPID credentials to book a new appointment, the system associated, via the citizen's tax code, the data previously collected, proposing the email address entered on XX by the operator.

In this case, the entry of incorrect data appears to be attributable to the peculiar circumstances of the same, and in particular, to the intervention of the municipal operator who, on one hand, while providing support to the claimant, mistakenly used the user procedure (instead of the one intended for operators), and on the other hand, indicated their own email address as the contact data, instead of that of the user.

Nevertheless, in the issue raised by the claimant, the settings of the booking system implemented by the Ministry have nonetheless played a significant role. The provision for long retention periods of data and accounts, which remained active even after the date of the appointments, whether expired or canceled, and even after the issuance of the CIE - even in the absence of human error (as in the present case) - nonetheless posed the risk of reintroducing outdated data (for example, email addresses and phone numbers no longer active or no longer used by the user), jeopardizing the achievement of the purposes underlying the collection of contact data as indicated in the legal basis, which is to "receive communications from CIEonLine regarding the status of the CIE issuance process" (Ministerial Decree of December 23, 2015, Annex B).

Having said that, from the examination of the documentation acquired during the investigation, it is observed that for the mere booking of an appointment, the creation of a user account on the "CIE-Online Agenda" system is not necessary, which therefore cannot be set by default and maintained active regardless of the presence of an appointment. This is because the identity document - in general and barring the case of theft or loss - has a ten-year validity, and the request for a new document is not a frequent event for the citizen.

The possibility of creating a user account, therefore, should be left optionally to the interested party, should they wish to maintain it for subsequent uses (for example, to request an appointment for the issuance of the CIE for minor children). Therefore, access to the "CIE-Online Agenda" system and the booking of an appointment should not, by default, necessarily entail the maintenance of a user account in the system, unless explicitly requested by the interested party.

Furthermore, based on the investigation carried out, it appears that, at the time of the events subject to the complaint, the "CIE-Online Agenda" system:

1. Retained the account created during the request for an appointment for the issuance of the CIE

even after the dispatch or collection of the document by the citizen, thus regardless of the stated needs for scheduling or managing the appointment at the chosen municipal office;

2. The user profile, in the "appointment management" section, retained the history of all appointments scheduled by the interested party (appointment number, date, time, office), including those... the application of the administrative monetary sanction and accessory penalties (articles 58, paragraph 2, letter i), and 83 of the Regulation; article 166, paragraph 7, of the Code).

The violation of articles 5, paragraph 1, letters a), b), and e), and 6 of the Regulation entails the application of the administrative sanction provided for by article 83, paragraph 5 of the Regulation.

The Authority, pursuant to articles 58, paragraph 2, letter i) and 83 of the Regulation as well as article 166 of the Code, has the power to "impose an administrative monetary sanction pursuant to article 83, in addition to [other] corrective measures [referred to in this paragraph], or in lieu of such measures, depending on the circumstances of each individual case" and, in this context, "the College [of the Authority] adopts the injunction order, which also provides for the application of the administrative monetary sanction."

****Regarding the application of the administrative sanction accessory to its publication, in whole or in part, on the website of the Authority pursuant to Article 166, paragraph 7, of the Code**** (Article 16, paragraph 1, of the Regulation of the Authority No. 1/2019).

Considering that the violation of the aforementioned provisions by the Ministry of the Interior occurred as a result of conduct that can be considered unitary (same treatment or treatments connected to each other), Article 83, paragraph 3, of the Regulation applies, according to which the total amount of the administrative pecuniary sanction does not exceed the amount specified for the most serious violation. Considering that, in the specific case, all violations are subject to the sanction provided for by Article 83, paragraph 5, of the Regulation, as also referred to by Article 166, paragraph 2, of the Code, the total amount of the sanction is to be quantified up to €20,000,000 (twenty million/00).

With reference to the elements listed in Article 83, paragraph 2 of the Regulation for the purpose of applying the administrative pecuniary sanction and its quantification, considering that the sanction must be "effective, proportionate, and dissuasive in each individual case" (Article 83, paragraph 1 of the Regulation), it is represented that, in the case at hand, the following circumstances have been taken into account.

With specific regard to the particular nature, severity, and duration of the violation, while considering that the investigation did not reveal similar cases to that subject of the complaint, the treatment overall carried out on the "CIE-Online Agenda" system as described above involved a very high number of individuals whose data were stored in the system for a period of two years; on the other hand, the treatment does not appear to be characterized by particular sensitivity, considering the purpose of the treatment (appointment for CIE request and the nature of the requested data (personal and contact data) (Article 83, paragraph 2, letter a) of the Regulation).

In light of these circumstances, it is believed that, in this specific case, the level of severity of the violation committed by the data controller can be considered low (cf. European Data Protection Board, "Guidelines 04/2022 on the calculation of administrative fines under the GDPR" of May 23, 2023).

That said, it is believed that, for the purpose of quantifying the sanction, the timely addressing of the issue raised by the complainant – through the help desk available to users – regarding the need to rectify the inaccurate data recorded in the system (Article 83, paragraph 2, letter c) of the Regulation); the degree of cooperation shown by the data controller with the supervisory authority in order to remedy the violation and mitigate its possible negative effects, having adopted measures during the investigation to make the processing of users' data carried out on the "CIE-Online Agenda" system compliant with the Regulation (Article 83, paragraph 2, letter f) of the Regulation); the absence of previous relevant violations committed by the data controller (Article 83, paragraph 2, letter e) of the Regulation) should be taken into account favorably.

It is also believed that the circumstance that the infringing party is a central administration of national

significance is relevant in this specific case, due to the aforementioned principles of effectiveness, proportionality, and dissuasiveness to which the Authority must adhere in determining the amount of the sanction (Article 83, paragraph 1, of the Regulation).

In light of the aforementioned elements, assessed as a whole, it is deemed appropriate to determine the amount of the pecuniary sanction at €3,000.00 (three thousand) for the violation of Articles 5, paragraph 1, letters a), b), and e), and 6 of the Regulation, as the administrative pecuniary sanction deemed, pursuant to Article 83, paragraph 1, of the Regulation, effective, proportionate, and dissuasive.

In this context, it is also believed that, pursuant to Article 166, paragraph 7, of the Code and Article 16, paragraph 1, of the Regulation of the Authority No. 1/2019, the publication of this section containing the injunction order on the Authority's website should proceed. This is in consideration of the circumstance that the sanctioned treatment involved a very high number of citizens who used the Ministry of the Interior's "CIE-Online Agenda" system for the purpose of booking an appointment for the issuance of the identity document.

It is finally noted that the conditions referred to in Article 17 of Regulation No. 1/2019 are met.

****ALL OF THE ABOVE CONSIDERED, THE AUTHORITY**** pursuant to Articles 57, paragraph 1, letter f) of the Regulation, finds the unlawfulness of the processing carried out by the Ministry of the Interior - Department for Internal and Territorial Affairs, for the violation of Articles 5, paragraph 1, letters a), b), and e), and 6 of the Regulation as stated in the reasoning;

****ORDERS**** pursuant to Articles 58, paragraph 2, letter i) and 83 of the Regulation, as well as Article 166 of the Code, the Ministry of the Interior - Department for Internal and Territorial Affairs, with legal headquarters at Palazzo del Viminale, C.F. 97149560589, 00184, Rome, to pay the total sum of €3,000.00 (three thousand) as an administrative pecuniary sanction for the violations indicated in the reasoning.

It is noted that the infringer, pursuant to Article 166, paragraph 8, of the Code, has the right to... define the dispute by payment, within the deadline of 30 days, of an amount equal to half of the imposed sanction;

ORDERS

the Ministry of the Interior - Department for Internal and Territorial Affairs, to pay the total amount of 3,000.00 (three thousand) in case of failure to resolve the dispute pursuant to art. 166, paragraph 8, of the Code, according to the methods indicated in the annex, within thirty days from the notification of this provision, under penalty of the adoption of the consequent executive acts in accordance with art. 27 of law no. 689/1981;

DISPOSES

pursuant to art. 166, paragraph 7, of the Code and art. 16, paragraph 1, of the Regulation of the Guarantor no. 1/2019, the publication of the injunction order on the Guarantor's website; pursuant to art. 154-bis, paragraph 3 of the Code and art. 37 of the Regulation of the Guarantor no. 1/2019, the publication of this provision on the website of the Authority; pursuant to art. 17 of the Regulation of the Guarantor no. 1/2019, the annotation of this provision and the measures adopted pursuant to art. 58, paragraph 2, of the Regulation, in the internal register of the Authority,

provided for by art. 57, paragraph 1, letter u), of the Regulation.

Pursuant to arts. 78 of the Regulation, 152 of the Code and 10 of Legislative Decree no. 150/2011, against the present provision it is possible to appeal before the ordinary judicial authority, under penalty of inadmissibility, within thirty days from the date of communication of the provision itself or within sixty days if the appellant resides abroad.

Rome, February 27, 2025

THE PRESIDENT

Stanzione

THE REPORTER

Stanzione

THE SECRETARY GENERAL

Mattei